



Gelinkt

Gefahren durch manipulierte QR-Codes

Kriminelle nutzen Schwächen der Smartphone-Kamera-Apps aus, um mit manipulierten QR-Codes zu betrügen, Zugangsdaten abzuphishen oder Zahlungen umzuleiten. Eine QR-Code-Reader-App zeigt Ihnen den wahren Inhalt.

Von Mirko Dölle

Die kleinen Quadrate finden sich heute überall, auf Produkten, Aufklebern, Plakaten und in Logos: QR-Codes verdrängen die altbekannten Strichcodes, weil sich damit mehr Informationen auf kleinerer Fläche unterbringen lassen. Außerdem bieten sie vielfältigere Möglichkeiten: Barcodes, wie sie weiterhin an

Kassen im Supermarkt eingescannt werden, enthalten lediglich Ziffern, eine Produktnummer. QR-Codes hingegen können neben Seriennummern auch Internetadressen, Bilder, Dokumente oder Binärdateien enthalten.

Kriminelle missbrauchen QR-Codes für ihre Zwecke. Wer unbedarft QR-Codes scannt und die darin hinterlegten Adressen ansurft, landet womöglich auf Fake-Seiten und riskiert, Opfer von Phishing und Identitätsdiebstahl zu werden. Wir zeigen Ihnen, wie leicht Sie hinters Licht geführt werden können und wie Ihnen eine dedizierte QR-Code-Leser-App zum Durchblick verhilft.

Als QR-Codes werden umgangssprachlich alle zweidimensionalen Codes bezeichnet, so sind neben dem Kodierungsverfahren QR (Quick Response) auch Aztec und DataMatrix weit verbreitet. Sie haben eine quadratische Grundform und sind zweifarbig, meist

schwarz-weiß. Es gibt aber auch mehrfarbige Varianten. Sie haben eine weitaus höhere Informationsdichte als ein dimensionale Strich- oder Barcodes. Ein 2D-Code kann im Extremfall mehrere Kilobyte Daten enthalten – je mehr Informationen, desto größer werden seine Abmessungen. Passmarken oder Ränder helfen dem Leser, das Bild zu entzerren, falls der Code nicht senkrecht von oben gescannt wird.

Prinzipiell können 2D-Codes beliebige Daten enthalten, auf Typenschildern von Geräten ist das oft die Seriennummer – oder auf Bahntickets neben der Ticketnummer noch eine Signatur, anhand derer sich die Echtheit überprüfen lässt. QR-Codes werden oft mit URLs bestückt, damit Menschen sie mit ihren Smartphones abfotografieren und, dank QR-Code-Lesern der Kamera-Apps, die Websites besuchen können, ohne die Adresse von Hand eingetippen zu müssen.

Die Codes werden inzwischen praktisch überall und für so ziemlich alles eingesetzt – von Autoaufklebern mit der Firmen-URL über bunt bemalte Rettungswagen und Feuerwehrautos, die beim Fotografieren auf eine Anti-Gaff-Kampagne verweisen, bis hin zu Rechnungsdaten inklusive Bankverbindungen beim Online-Banking. Kaum jema

denkt noch darüber nach, was ein QR-Code enthält – man scannt ihn arglos mit dem Smartphone, sobald man darauf stößt.

Schwer zu durchschauen

Das Problem ist, dass Ihnen sowohl die Kamera-Apps des iPhone als auch die in Android nicht die ganze Wahrheit über die gescannten QR-Codes verraten, sondern deren Inhalt interpretieren und versuchen, die Essenz zu destillieren. Das ist gut gemeint, aber wie so oft nicht immer gut gemacht. So kann man leicht auf Phishing- und Hacker-Angriffe hereinfallen, wenn man auf die QR-Code-Leser der Kamera-Apps vertraut.

Ein Beispiel gefällig? Angenommen, Sie sind in der Innenstadt von Hannover unterwegs und wollen sich einen E-Scooter ausleihen. Sie finden einen freien Roller, zum Beispiel vom Mobilitätsdienstleister Bolt. Die nachfolgend beschriebenen Angriffsmöglichkeiten betreffen alle E-Scooter-Anbieter, die mit einem QR-Code am Fahrzeug arbeiten, gleichermaßen. Bolt wurde ausschließlich als exemplarisches Beispiel gewählt und steht stellvertretend für die gesamte Branche.

Sie finden am Lenkrohr einen QR-Code, den Sie zum Ausleihen mit der Kamera-App Ihres Smartphones scannen. Am unteren Bildschirmrand zeigt Ihnen die App mit einem Browser-Symbol an, dass es sich um eine Internetadresse handelt. Sie bekommen jedoch nicht die vollständige URL angezeigt, sondern auf Android-Geräten nur den Anfang der URL, so weit, wie das Anzeigeelement in der Breite reicht. Apple-Geräte zeigen das Ende der URL, meist nur die Second- und Top-Level-Domain, mitunter noch die Third-Level-Domain.

So bekamen wir auf einem Samsung S25 Ultra nach dem Scannen eines QR-Codes lediglich „de.escooters.bolt.mob...“ angezeigt – was durchaus plausibel aussieht, wenn man gerade versucht, einen E-Scooter von Bolt auszuleihen. Weitere Bestandteile der URL wie zum Beispiel die Roller-ID an deren Ende sehen Sie in der Kamera-App nur dann, wenn Sie die Details des QR-Codes abrufen. Bei einem iPhone 16e zeigte uns Apples Kamera-App nach dem Scannen eines weiteren Barcodes „bolt.mobi%2emba“ an – auch da läuten nicht sofort die Alarmglocken, wenn man gerade einen E-Scooter mit der ID „2emba“ von einem Mobilitätsdienstleister ausleihen möchte.

ct kompakt

- Die QR-Code-Leser in den Kamera-Apps von Android und iOS zeigen Ihnen nur die halbe Wahrheit über Links.
- Mit geschickt gewählten URLs können Kriminelle unaufmerksame Nutzer etwa auf täuschend echt aussehende Phishing-Seiten umleiten.
- Dedizierte QR-Code-Leser-Apps zeigen Ihnen, was hinter dem gescannten QR-Code wirklich steckt.

Unscheinbar

Doch der Schein trügt. So nutzt Bolt für seinen Internetauftritt die Domain bolt.eu. Auf den QR-Codes der E-Scooter hingegen steht eine Adresse der Art „https://scooters.taxify.eu/qr/123-456“. Zu welchem Unternehmen der Link führt, ist für den Kunden vor Ort nicht zu erkennen. Das können Kriminelle ausnutzen, indem sie den QR-Code auf dem E-Scooter mit einem eigenen überkleben – der zum Beispiel die Adresse „https://de.escooters.bolt.mobi.mba/qr/123-456“ enthält. Dass der QR-Code zur Domain mobi.mba führt, ist in der Kamera-App nicht zu sehen, der Kunde sieht lediglich „bolt.mob...“ am Ende und wähnt sich in Sicherheit.

Hinterlegen Betrüger auf „mobi.mba“ einen Link, der zu einer Phishing-App oder einer Website im Gewand der Bolt-App führt, werden die Möchtegern-Kunden allenfalls dann stutzig, wenn nach Abschluss von Registrierung und Eingabe der Zahlungsinformationen der gewünschte Roller nicht entsperrt wird. Die Daten sind dann längst an die Betrüger abgeflossen.

Auf iPhones können Betrüger sogar einen Darstellungsfehler des QR-Code-Lesers in der Kamera-App ausnutzen, um vermeintliche Kunden abzuzocken. Der Trick ist, die wahre Internetadresse über sogenannte Adresskodierung (URL-Encoding) zu verschleiern. Darauf fällt Apples App unter bestimmten Umständen herein, wie Sie auf Seite 46 nachlesen können.

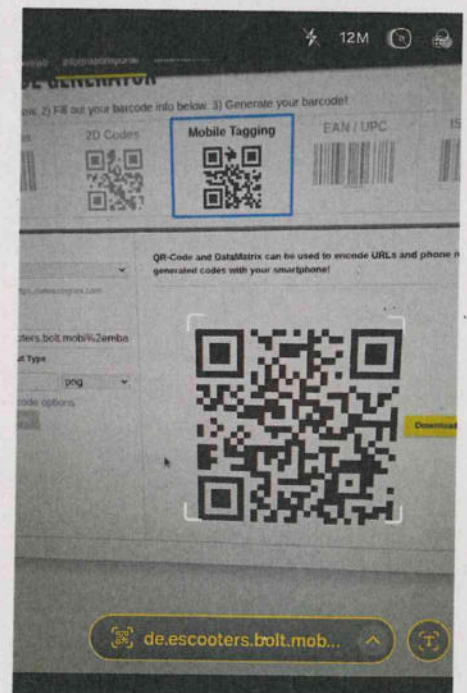
Verschleiert

Bei Apples Foto-App können Angreifer ausnutzen, dass die App versucht, mindestens die Second- und Top-Level-Domain

festzustellen – und dabei unter bestimmten Umständen scheitert. Als Nutzer darf man erwarten, dass Apples Kamera-App bei einem QR-Code mit der URL https://www.heise-online.de die Adresse „heise-online.de“ anzeigt.

Die URL enthält zwar keine Zeichen, die per Adresskodierung umgewandelt werden müssten – es ist aber auch nicht verboten, den Punkt vor der Top-Level-Domain „de“ in URL-Kodierung als „%2e“ zu schreiben. Für den QR-Code-Leser in Apples Kamera-App ist das kein Problem, sie wandelt die URL-Kodierung in den gewohnten Punkt um und zeigt Ihnen als Adresse weiterhin „heise-online.de“ statt „heise-online%2ede“ an.

Auch die URL „https://bolt.mobi.mba/2emba“ enthält keine Zeichen, die URL-kodiert werden müssten. Scannen Sie einen QR-Code mit dieser Adresse, so zeigt Ihnen die Kamera-App korrekt „bolt.mobi.mba“ an. Wird der Punkt vor „mba“ jedoch URL-kodiert, lautet die Adresse im QR-Code nun also „https://bolt.mobi%2emba/2emba“, so zeigt die Kamera-App auf dem iPhone hingegen „bolt.mobi%2emba“ an. Ein „%“ und ein „/“ sind schnell verwechselt und wer nicht weiß, dass „%2emba“ für „mba“ steht,



Der QR-Code-Leser in der Kamera-App von Android-Smartphones zeigt den Anfang von URLs an – so weit der Platz auf dem Display eben reicht. Dass dieser Barcode zu einer Adresse der Domain bolt.mobi.mba führt, ist nicht zu erkennen.

geht davon aus, die Adresse „bolt.mobi“ zu besuchen.

Unverdächtige Adressen für Android-Smartphones zu erzeugen, ist ungleich leichter, da hier stets nur der Anfang angezeigt wird und sich somit jede Second-Level-Domain für Angriffe eignet – man muss sich nur ein paar genügend lange, aber plausibel klingende Präfixe ausdenken.

Ausgetrickst

Weil sie mit bloßem Auge eben nicht – oder nur für sehr wenige – lesbar sind, sollten Sie QR-Codes mit besonderer Skepsis begegnen. Sie werden nicht nur für Betrüge-reien missbraucht, sondern auch für unerwünschtes Tracking. Für Firmen können vor allem Programme und Webseiten, die QR-Codes erzeugen, zum Datenschutzproblem werden, wie das Beispiel einer großen deutschen Versicherung zeigt. Dazu später mehr.

Nicht nur die QR-Codes auf E-Scootern lassen sich leicht manipulieren, auch auf Wahl- und Werbeplakaten ist es für Betrüger leicht, die QR-Codes zu überkleben. Auch die QR-Codes an Regalen von Discountern und Supermärkten, die Hintergrundinformationen zu den Artikeln oder Rabatte versprechen, sind leichte Manipulationsziele.



Apples Kamera-App scheitert bei bestimmten URLs, kodierte Zeichen korrekt umzuwandeln. Wohin der Link wirklich führt, erkennen nur Eingeweihte.

Dabei kommt den Betrügern die Praxis der Händler entgegen, Sonderangebote von der Nutzung von Apps sowie einer Registrierung abhängig zu machen. Wer wird schon misstrauisch, wenn er nach dem Scannen des QR-Codes im Laden aufgefordert wird, auf einer täuschend echt aussehenden Website im Look der App die Zugangsdaten für seinen Discounter-Account einzugeben?

Aufwendig, aber besonders lukrativ sind gefälschte Rechnungen oder vorgebliche amtliche Bescheide mit EPC-QR-Codes. EPC-QR-Codes sind nach den Richtlinien des European Payment Councils formatierte QR-Codes, die alle für eine Überweisung notwendigen Informationen enthalten und von manchen Online-Banking-Apps direkt eingescannt werden können.

Solche Manipulationen sind eine Weiterentwicklung älterer Betrugsmaschinen, bei denen etwa ein Bauherr eine Abschlagzahlung vorgeblich gegenüber einem der beauftragten Handwerksbetriebe leisten soll. Manchmal wird auch eine Abschlussrechnung oder ein Steuerbescheid fingiert, dabei haben die Täter sowohl Firmen als auch Privatkunden im Visier. Der Aufwand ist für die Betrüger aber erheblich, da sie Baustellen oder Betriebe vor Ort ausspähen oder gar infiltrieren müssen. Der EPC-QR-Code wird dann genutzt, um auf der nachgemachten Rechnung eine falsche Bankverbindung zu verstecken.

Tracking wider Willen

Weil die Kamera-Apps der Smartphones nur kleine Ausschnitte der Adresse aus einem QR-Code im Klartext anzeigen, lassen sich leicht Tracking-Informationen anfügen. Bei den E-Scooter-Verleihern zum Beispiel enthält die URL des QR-Codes stets auch die Identifikationsnummer des Rollers. Auf gleiche Weise kann zum Beispiel der QR-Code eines Gutscheins oder ein Rabattcode um eine ID ergänzt werden, die dem werbenden Unternehmen verrät, wer der ursprüngliche Adressat war oder über welche Werbekampagne der Kunde angesprochen wurde. Letzteres ist ein beliebtes Instrument im Marketing, um die Reichweite verschiedener Werbekanäle zu messen.

Manchmal sind es jedoch auch die Anbieter von Software oder Websites, die QR-Codes erzeugen, die mehr oder weniger heimlich die Reichweite tracken. Das kann für Firmen, die diese QR-Codes ver-

breiten, zum Datenschutzproblem werden. So bietet der Link-Verkürzungsdienst Bitly an, QR-Codes mit Links auf die Domain qrco.de zu generieren, die Besucher auf die Website des Kunden weiterleiten. Bitly übernimmt das Tracking und die Auswertung für die Marketingabteilung der Auftragsfirmen, wovon Nutzer praktisch nichts mitbekommen, da sie ohne jeglichen sichtbaren Hinweis und praktisch ohne Verzögerung auf der eigentlich gewünschten Seite landen.

Datenschutzrechtlich problematisch ist jedoch, dass durch den Umweg über die Server des US-Unternehmens personenbezogene Daten außerhalb der EU landen und dort auch gespeichert werden, allem voran die IP-Adresse. Eine große deutsche Versicherung nutzte den QR-Code von Bitly, um auf ihren Briefumschlägen für ein konkretes Versicherungsangebot zu werben und die Resonanz darauf von Bitly tracken zu lassen. Dazu liegt jedoch keine Einwilligung vor, die Versicherung gab auch die URL nicht unter dem QR-Code im Klartext an. Wer arglos den Link des gescannten QR-Codes öffnet, outet sich über die IP-Adresse auch als zugehörig zu einer bestimmten Personengruppe und als Interessent für ein ganz bestimmtes Versicherungsangebot.

Die ganze Wahrheit

Die meisten kostenlosen Onlinedienste erzeugen aber QR-Codes ohne Tracking, etwa der der TU Chemnitz oder der von Cognex (siehe ct.de/yvqb). In jedem Fall sollten Sie aber überprüfen, ob das Ergebnis korrekt ist und nicht doch eine Umleitung erfolgt. Dazu benötigen Sie einen QR-Code-Reader, der Ihnen die ganze Wahrheit und nichts als die Wahrheit über einen QR-Code verrät. Und auch für Nutzer ist eine solche App enorm hilfreich.

Wir empfehlen die App „Barcode Scanners“ (iOS) respektive „Barcode Scanner“ (Android) der Cognex Corporation (siehe ct.de/yvqb). Wir verwenden sie seit über zehn Jahren zum Lesen aller Formen von Barcodes und QR-Codes und hatten sie schon zu Zeiten installiert, bevor die Softwareentwicklungsfirma Manatee Works von Cognex gekauft wurde, einem Hersteller von industriellen Bilderkennungs- und Kamerasystemen für die automatische Qualitätskontrolle in Produktionslinien.

Die App ist nicht nur kostenlos, sondern auch werbefrei, und sie sammelt nach unseren Recherchen keine Daten für

den Hersteller. Es gibt sie allerdings nur auf Englisch, was aber kaum ins Gewicht fällt. Sie ist damals wie heute eigentlich nur als Technikdemonstration für das Barcode-SDK gedacht, das Cognex an Softwareentwickler lizenziert, und lässt sich deshalb sehr weitreichend konfigurieren. So können Sie zum Beispiel unterschiedliche Barcode-Typen an- oder abschalten und so die Lesegeschwindigkeit oder den Energieverbrauch verbessern.

Das Wichtigste aber: Die App zeigt die Daten erkannter Barcodes vollständig und völlig unverändert an. Nicht druckbare Zeichen repräsentiert sie mit ihrem Hexadezimalcode. Damit ist sie perfekt dafür geeignet, den wahren Inhalt von QR-Codes zu ergründen – bietet auf Wunsch aber auch an, einen erkannten Link im Browser zu öffnen.

Es gibt auch zahlreiche andere kostenlose Barcode- und QR-Code-Apps, die jedoch mitunter werbefinanziert oder mit Preisvergleichsportalen verknüpft sind und bei denen unklar ist, ob sie den unver-

fälschten Inhalt von QR-Codes anzeigen – oder nicht doch einzelne Zeichen konvertieren.

Argwöhnisch bleiben

Damit Sie nicht auf die verkürzten Ansichten in der Kamera-App Ihres Smartphones hereinfallen, sollten Sie die QR-Code-Unterstützung dort abschalten. Bei Android-Geräten finden Sie diese Option in den Einstellungen unter „Apps/Kamera/Kamera-Einstellungen“ als „QR-Codes scannen“. Auf dem iPhone gehen Sie in die Einstellungen und deaktivieren dort unter „Kamera“ ebenfalls „QR-Codes scannen“.

Neben einer App, die einem den wahren Inhalt der QR-Codes zeigt, ist ein aufmerksamer, wohlbedachter Umgang entscheidend, um Gefahren abzuwehren. So wie es sich eingebürgert hat, keinesfalls Links in dubiosen E-Mails anzuklicken, sollte man auch nicht einfach jeden Link aus einem QR-Code arglos öffnen – und auf keinen Fall irgendwelche Zugangsdaten auf einer so besuchten Seite einge-



Die App Barcode Scanner(s) von Cognex zeigt den Inhalt von QR-Codes und anderen Barcodes vollständig und unverfälscht an. Sie ist kostenlos, werbefrei und sammelt keine Daten.

ben. Denn das ist es, worauf die Betrüger nur warten. (mid@ct.de) **ct**

QR-Code-Reader und -Generatoren:
ct.de/yvqb

IT SUMMIT by heise

Trump-Risiken? Plan B erfahren.



11. und 12. November in München

Jetzt informieren
it-summit.heise.de